INFORMATION GAHTERING

GIUSEPPECARBONEDEV.COM

TANCREDI
DE SIMONE

1 Introduzione

L'information gathering è la prima fase del vulnerability assesment, ci permette di avere appunto tutte le infromazioni riguardanti il nostro target di riferimento, per poterle sfruttare nel penetration test.

E' una fase importantissima che viene a volte saltata, ma accorcia notevolmente i tempi, sapere dove andare a premere per un attacco efficace è fondamentale. In questo esercizio andremo a raccogliere informazioni sul sito **giuseppecarbonedev.com** cercando di avere un quadro completo del dominio, sfortunatamente Giuseppe non ci ha dato il permesso di eseguire un penetration test quindi ci limiteremo solo a raccogliere informazioni.

Utilizzeremo alcuni comandi phyton per estrarre i record DNS e il Google Dorking per fare ricerche approfondite riguardo Giuseppe e il suo sito.

2 Whois, informazioni DNS

2.1 Prime fasi, nslookup, dig

Per prima cosa nella mia macchina virtuale Kali ho iniziato con il comando **nslookup** che ci da alcune informazioni generali quali indirizzo ip pubblico e privato.

```
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ nslookup giuseppecarbonedev.com
Server:         192.168.1.1
Address:        192.168.1.1#53

Non-authoritative answer:
Name:   giuseppecarbonedev.com
Address: 217.160.46.114
```

Per informazioni più specifiche e dettagliate invece utilizzeremo il comando **dig** seguito da cosa vogliamo sapere nello specifico.

Dig A +short ci darà l'indirizzo ip pubblico (il +short serve a filtrare il dig e dirgli che ci serve solo quello che abbiamo scritto in precedenza) **A** quindi sta per ip

```
┌──(kali㉿kali)-[~]
└─$ dig giuseppecarbonedev.com A +short
217.160.46.114
```

Vediamo quindi che l'ip è **217.160.46.114**

NS +short NS sta per "name server" ci dice quindi il nome del server.

```
┌──(kali㉿kali)-[~]
└─$ dig giuseppecarbonedev.com NS +short
ns1106.ui-dns.de.
ns1033.ui-dns.biz.
ns1056.ui-dns.org.
ns1034.ui-dns.com.
```

MX +short dove MX è il "mail server".

```
┌──(kali㉿kali)-[~]
└─$ dig giuseppecarbonedev.com mx +short
10 mx00.ionos.it.
10 mx01.ionos.it.
```

Con questi semplici comandi adesso abbiamo le informazioni di base del DNS del sito.

TXT +short dove TXT sta per “testo” serve a cercare file con estensione txt.

```
┌──(kali㉿kali)-[~]
└─$ dig giuseppecarbonedev.com txt +short
"v=spf1 include:_spf-eu.ionos.com ~all"
```

2.2 Whois

Ora passiamo al **Whois**, è un comando che ci informa sulle licenze del dominio, quando sono state fatte, da chi, la data di scadenza e a che server si appoggia il sito.

```
┌──(kali㉿kali)-[~]
└─$ whois giuseppecarbonedev.com
   Domain Name: GIUSEPPECARBONEDEV.COM
   Registry Domain ID: 3085560970_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.ionos.com
   Registrar URL: http://www.ionos.com
   Updated Date: 2026-04-07T22:45:37Z
   Creation Date: 2026-04-07T22:45:36Z
   Registry Expiry Date: 2027-04-07T22:45:36Z
   Registrar: IONOS SE
   Registrar IANA ID: 83
   Registrar Abuse Contact Email: abuse@ionos.com
   Registrar Abuse Contact Phone: +1.6105601459
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Name Server: NS1033.UI-DNS.BIZ
   Name Server: NS1034.UI-DNS.COM
   Name Server: NS1056.UI-DNS.ORG
   Name Server: NS1106.UI-DNS.DE
   DNSSEC: unsigned
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-05-04T13:11:30Z <<<
```

```
The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
Domain Name: giuseppecarbonedev.com
Registry Domain ID: 3085560970_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.ionos.com
Registrar URL: https://www.ionos.com
Updated Date: 2026-04-07T22:45:37.000Z
Creation Date: 2026-04-07T22:45:36.000Z
Registrar Registration Expiration Date: 2027-04-07T22:45:36.000Z
Registrar: IONOS SE
Registrar IANA ID: 83
Registrar Abuse Contact Email: abuse@ionos.com
Registrar Abuse Contact Phone: +1.8774612631
Reseller:
Domain Status: clientTransferProhibited https://www.icann.org/epp#clientTransferProhibited
Domain Status: addPeriod https://www.icann.org/epp#addPeriod
Registry Registrant ID: REDACTED FOR PRIVACY
Registrant Name: REDACTED FOR PRIVACY
Registrant Organization: REDACTED FOR PRIVACY
Registrant Street: REDACTED FOR PRIVACY
Registrant City: REDACTED FOR PRIVACY
Registrant State/Province: CE
Registrant Postal Code: REDACTED FOR PRIVACY
Registrant Country: IT
Registrant Phone: REDACTED FOR PRIVACY
Registrant Phone Ext:
Registrant Fax: REDACTED FOR PRIVACY
Registrant Fax Ext:
Registrant Email: dataprivacyprotected@ionos.de
Nameserver: ns1106.ui-dns.de
Nameserver: ns1056.ui-dns.org
Nameserver: ns1033.ui-dns.biz
Nameserver: ns1034.ui-dns.com
DNSSEC: Unsigned
URL of the ICANN WHOIS Data Problem Reporting System: http://wdprs.internic.net/
```

Alcune informazioni sono ovviamente oscurate per privacy.

Con questi pochi comandi ora abbiamo tutti i record DNS del dominio e possiamo procedere con il Google Dorking.

3 Google Dorking

Il Google Dorking è una tecnica utilizzata per sfruttare al massimo il noto motore di ricerca, utilizzando determinati comandi possiamo fare ricerche estremamente specifiche, filtrando i risultati esattamente come vogliamo noi. ogni ricerca sarà preceduta da **site:giuseppecarbonedev.com** un comando che ci permetterà di cercare solo sul dominio che ci sinteressa

3.1 Ricerca filetype

Con **filetype** andremo a ricercare alcuni file specifici, alcuni file pdf, excel, word o doc potrebbero avere alcune informazioni sensibili o dati di accesso, scriveremo nella barra di ricerca(or vuol dire oppure):

site:giuseppecarbonedev.com filetype:pdf OR filetype:txt OR filetype:doc OR filetype:xls OR filetype:env OR filetype:cfg

Con questa ricerca abbiamo ricercato questi tipi di file:

- Pdf
- Testo
- Documenti
- File excel
- File Fast API
- File di configurazione

operatori non sono stati applicati

Troppo poche corrispondenze trovate

Sembra che non ci siano molte corrispondenze per la tua ricerca:
"site:giuseppecarbonedev.com filetype:pdf OR filetype:txt OR filetype:doc OR filetype:xls OR filetype:env OR filetype:cfg"

- Prova con parole chiave più generiche
- Prova con meno parole chiave

Non abbiamo trovato corrispondenze

3.2 Ricerca inurl

Con il filtro **inurl** cerchiamo url del sito che hanno le parole che inseriremo nel filtro. Parole come “admin” o “login” possono essere incluse in alcuni url che hanno le informazioni di accesso.
site:giuseppecarbonedev.com inurl:login OR inurl:admin

operatori non sono stati applicati
Troppo poche corrispondenze trovate

Sembra che non ci siano molte corrispondenze per la tua ricerca:
"site:giuseppecarbonedev.com inurl:login OR inurl:admin"

- Prova con parole chiave più generiche
- Prova con meno parole chiave

Di nuovo, nessuna corrispondenza.

3.3 Ricerca intitle

Intitle ci permette di filtrare i risultati per titolo, filtreremo con “index of” per vedere se il sito ha cartelle pubbliche aperte o database.

site:giuseppecarbonedev.com intitle:”index of”

di nuovo, nessuna corrispondenza